Report di valutazione della sicurezza

Servizi SSH e FTP – Verifica di resistenza a credenziali deboli

Servizi analizzati	OpenSSH (porta 22) e vsftpd (porta 21)
Host analizzato	10.0.2.15 (interfaccia eth0 della VM Kali) e 127.0.0.1
Ambiente	Laboratorio isolato, uso didattico
Strumenti	Kali Linux, Hydra v9.7, client OpenSSH, liste SecLists
Data	13/11/2026
Esito complessivo	3 rilievi confermati: 2 alti, 1 medio; 2 osservazioni

1. Sintesi esecutiva

Durante la verifica sono stati testati i servizi di accesso remoto attivi sulla macchina Kali di laboratorio: SSH e FTP. Entrambi hanno accettato credenziali deboli. L'account test_osg su SSH accetta la password testpass, confermata da Hydra con un singolo tentativo. L'account test_user su FTP accetta la stessa password, individuata con un attacco a dizionario di 288 combinazioni completato in 43 secondi.

2. Ambito e metodologia

La verifica è stata condotta sulla macchina Kali del laboratorio. Gli indirizzi usati come bersaglio, 10.0.2.15 e 127.0.0.1, comandi Hydra:

SSH con test_osg verso 192.168.1.100

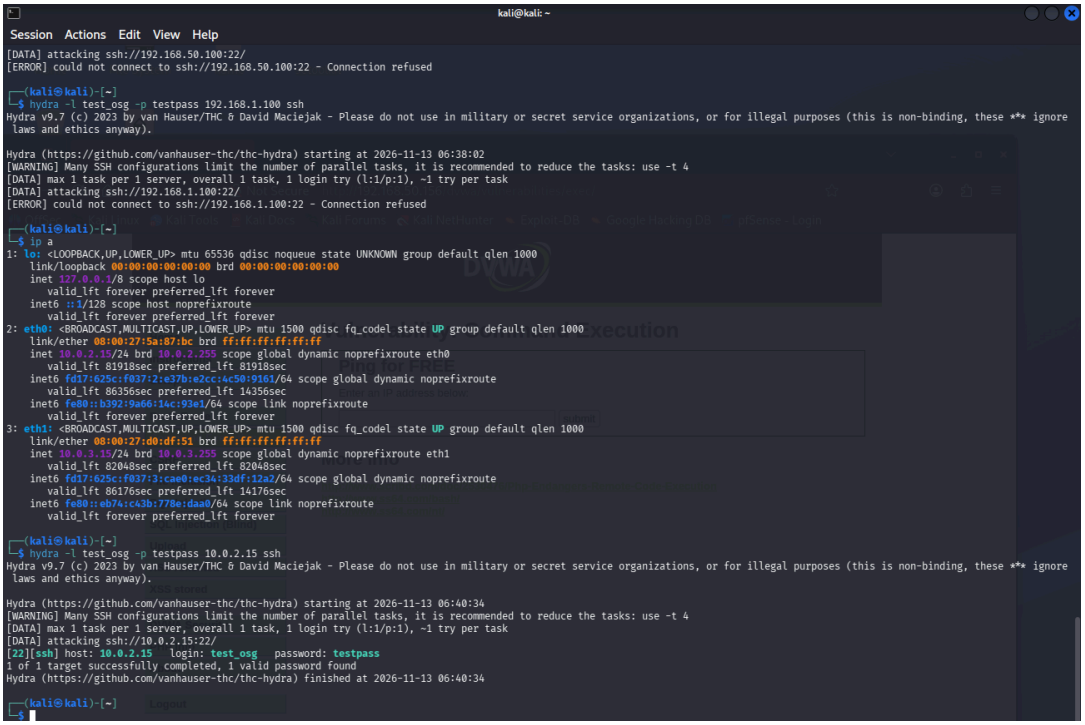
hydra -l test_osg -p testpass 192.168.1.100 ssh

SSH con test_osg verso 10.0.2.15

hydra -l test_osg -p testpass 10.0.2.15 ssh

Attacco a dizionario FTP su 127.0.0.1

hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt -P /usr/share/seclists/Passwords/Common-Credentials/best15.txt ftp://127.0.0.1 -t32 -V -o risultati15.txt . Le schermate in Allegato A mostrano i comandi e i risultati nell'ordine in cui sono stati ottenuti.



– Hydra su SSH con test_osg e password testpass: 192.168.50.100 e 192.168.1.100 rifiutati; 10.0.2.15 accetta le credenziali.

2.1 Descrizione dei passaggi

Sono partito da un tentativo di collegamento SSH dal terminale di Kali verso 192.168.50.156, con l'utente testusr. Il collegamento non va a buon fine: il client segnala di non trovare un tipo di chiave host compatibile, perché il server offre soltanto ssh-rsa e ssh-dss. Subito dopo ho controllato la configurazione di rete con ip a, che mostra eth0 su 192.168.50.100/24 ed eth1 su 10.0.3.15/24. Infine creato l'account test_osg(per puro test) con adduser, impostando la password e compilando i dati anagrafici di prova

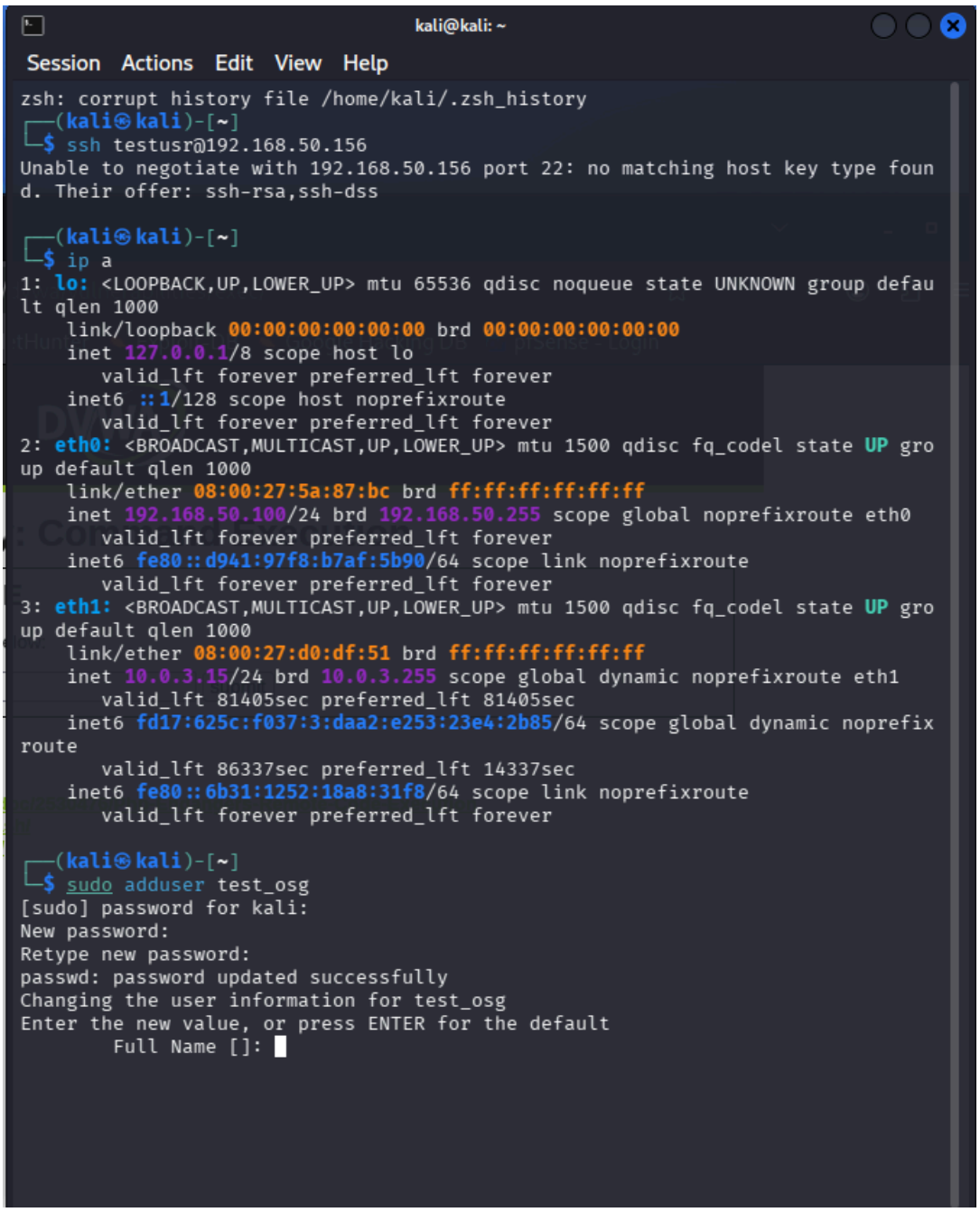


Figura 1 – Tentativo SSH verso 192.168.50.156 non negoziato; ip a; avvio della creazione dell'account test_osg.

Dopo la creazione dell'account il servizio viene avviato con sudo service ssh start, ma il tentativo verso 192.168.50.156 con test_osg fallisce per lo stesso motivo. Si prova quindi l'indirizzo di loopback 127.0.0.1. Il client mostra l'avviso di chiave sconosciuta, successivamente all'invio del yes la connessione si interrompe con «Broken pipe». Questo indica che sulla macchina non c'era un servizio SSH in ascolto e funzionante.

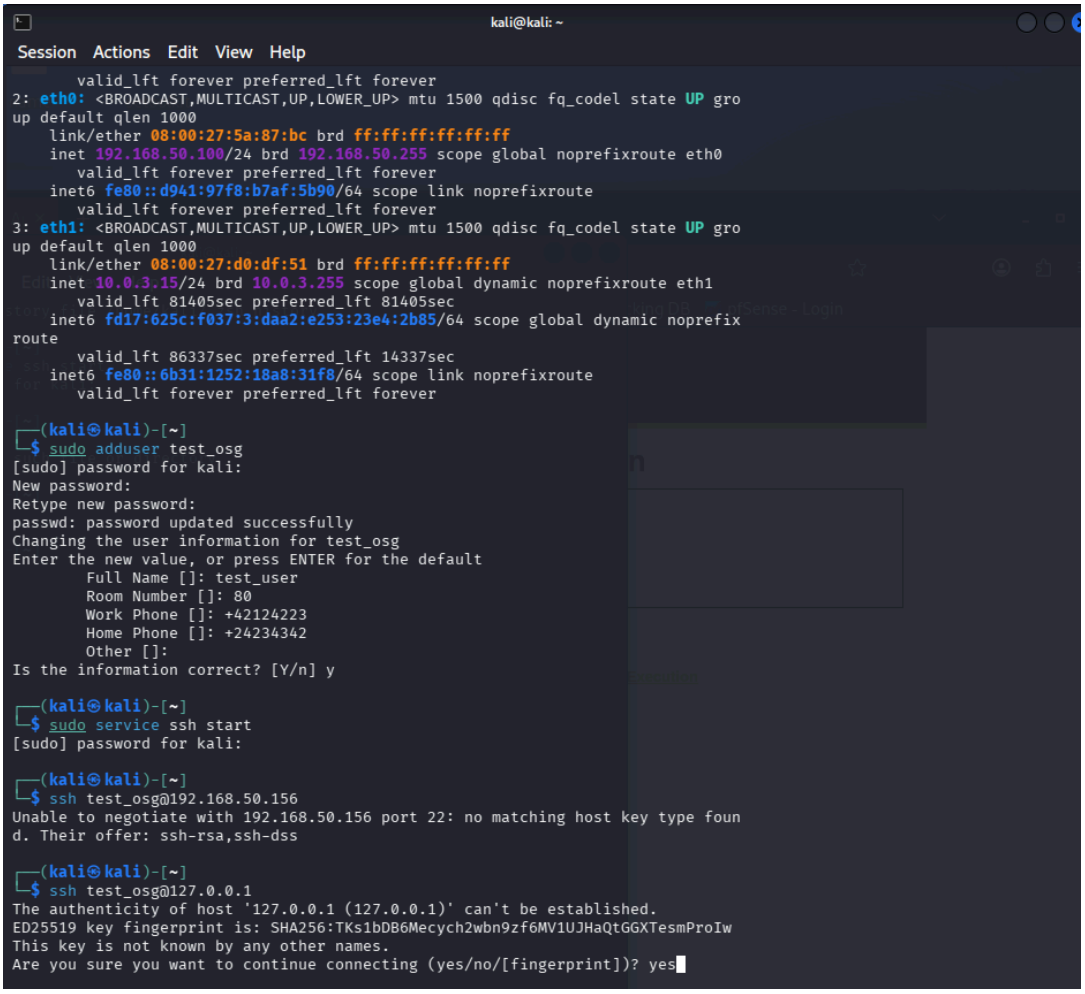


Figura 2 – Account test_osg completato; SSH verso 192.168.50.156 ancora non negoziato; accettazione della chiave host per 127.0.0.1.

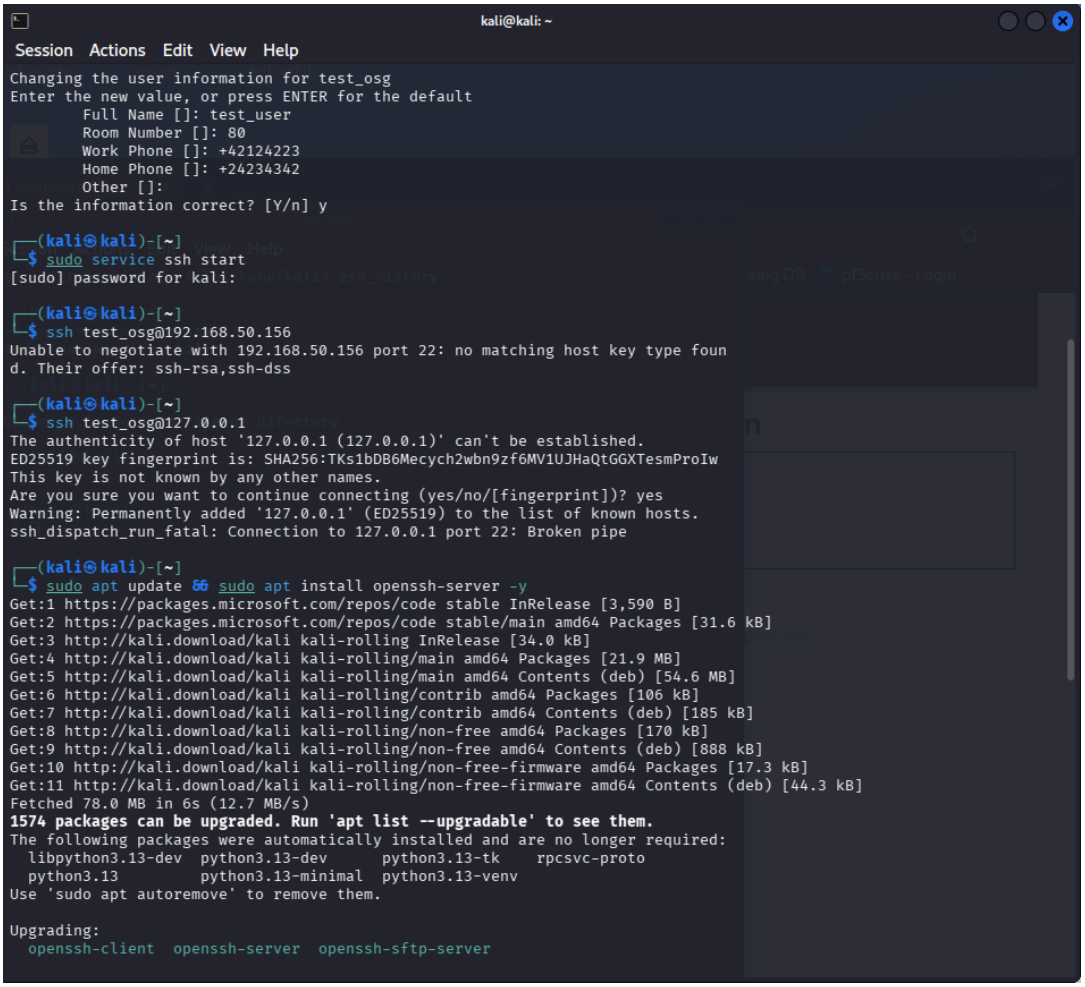


Figura 3 – Connessione a 127.0.0.1 interrotta («Broken pipe»); avvio dell'installazione di openssh-server.

Per risolvere, ho installato il pacchetto con sudo apt update && sudo apt install openssh-server -y. Il log mostra l'aggiornamento di openssh-client, openssh-server e openssh-sftp-server alla versione 1:10.6p1-1, e la generazione di una nuova chiave host. Il servizio viene poi avviato con sudo systemctl start ssh e il collegamento viene ripetuto: questa volta test_osg@127.0.0.1 chiede la password ed entra nella shell

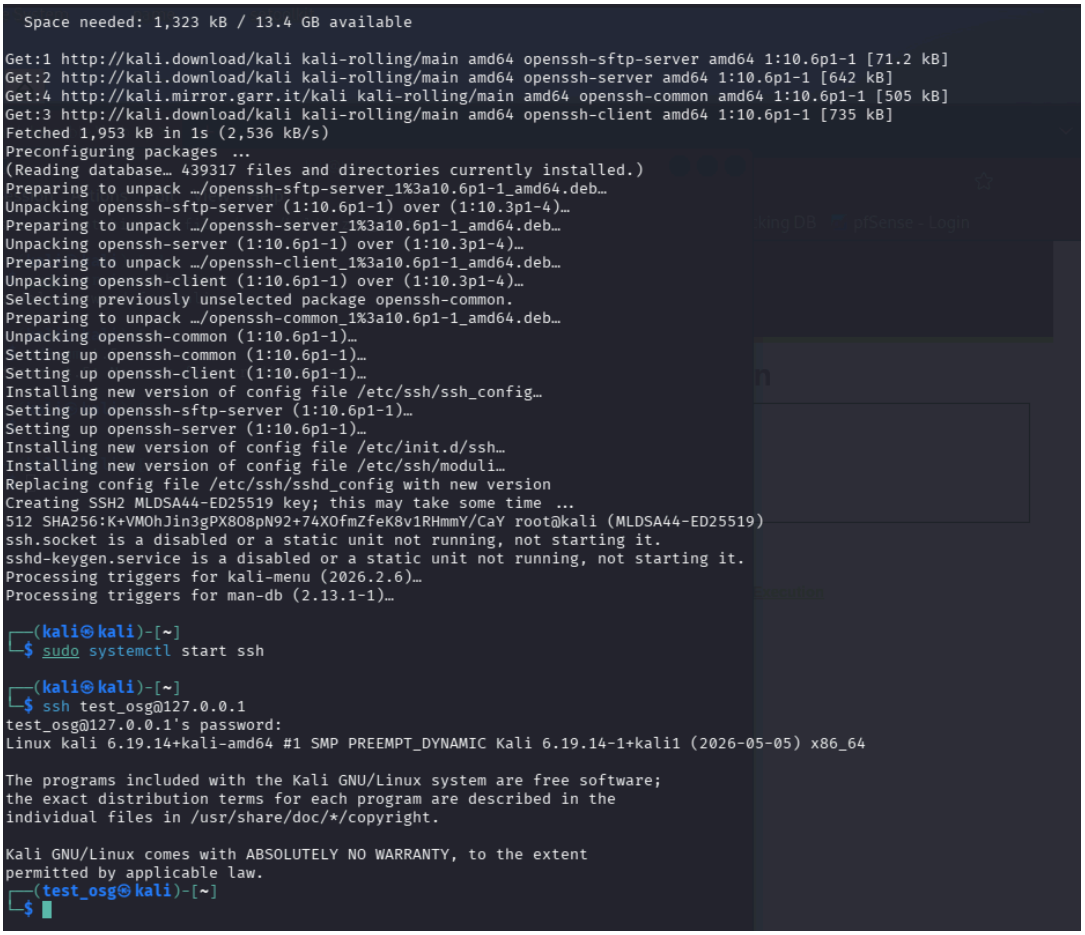


Figura 4 – Installazione di openssh-server, avvio del servizio SSH con systemctl e accesso come test_osg su 127.0.0.1.

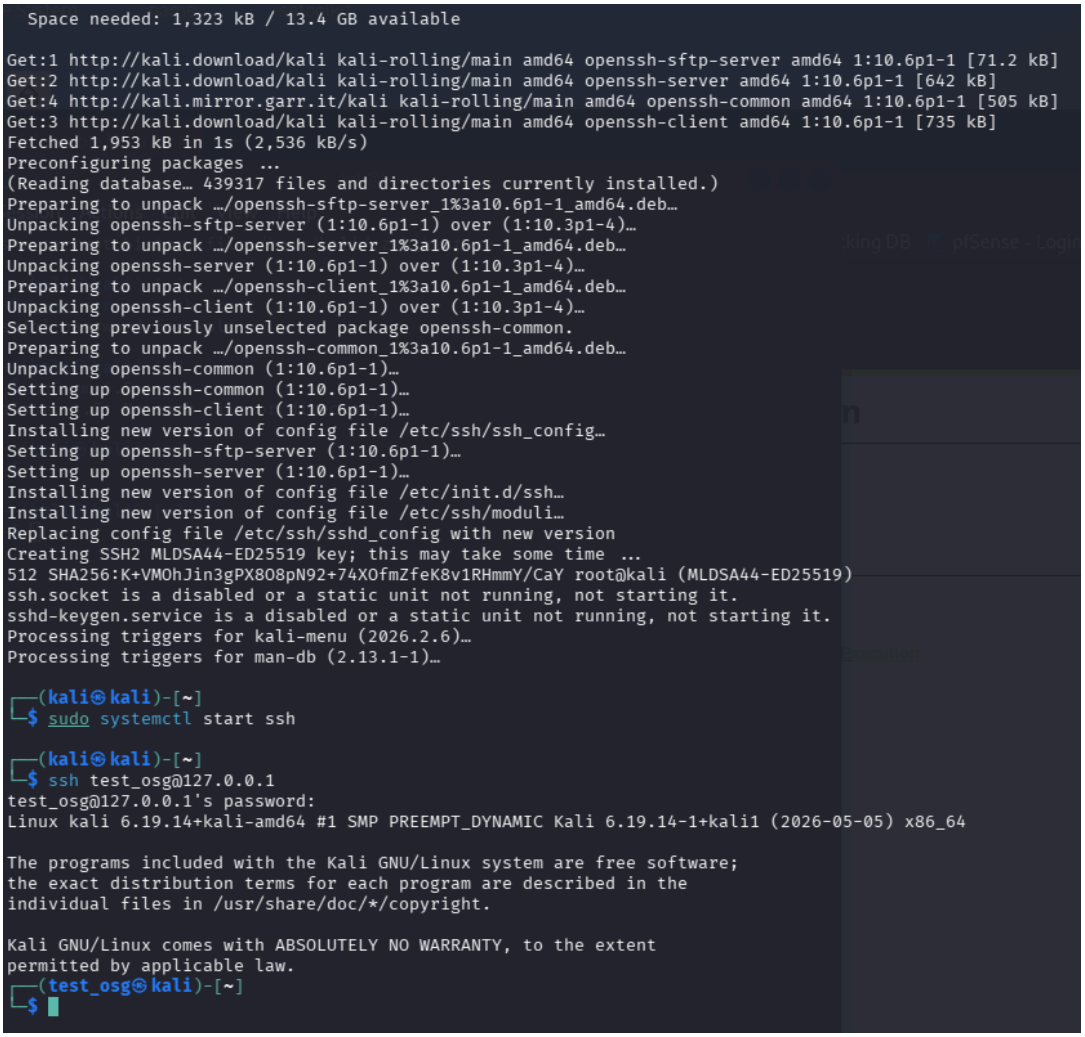


Figura 5 – Stessa fase della Figura 4 (vista alternativa): accesso SSH come test_osg dopo l'avvio del servizio.

Con l'accesso SSH funzionante, si passa a Hydra. Con l'utente test_osg e la password testpass vengono provate tre destinazioni. 192.168.50.100 e 192.168.1.100 rifiutano la connessione. 10.0.2.15, che nella stessa schermata risulta l'indirizzo di eth0, accetta le credenziali al primo tentativo .

Si lavora poi sul servizio FTP. Il comando sudo apt install vsftpd risponde che il pacchetto è già presente versione 3.0.5-1. Il servizio viene avviato con service vsftpd start e lo stato mostra active . Il servizio però risulta disabled all'avvio.

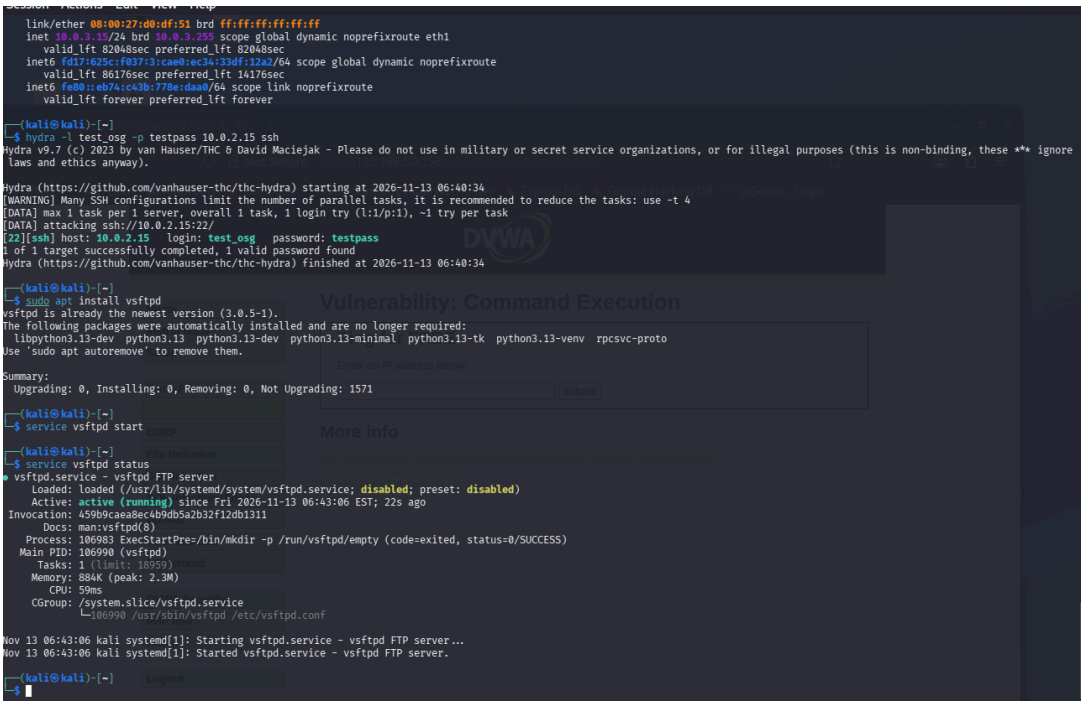


Figura 7 – Installazione e avvio di vsftpd; il servizio risulta attivo ma disabilitato all'avvio.

L'ultima fase riguarda l'accesso e l'attacco FTP. Prima ho provato l'accesso SSH come test_user su 10.0.2.15, che va a buon fine. Poi ho aggiunto con sudo tee -a la riga test_user alla lista degli utenti e la riga testpass alla lista delle password di SecLists. Avvia infine Hydra contro ftp://127.0.0.1 con 32 task paralleli e salva l'output in risultati15.txt . L'attacco scorre le 288 combinazioni tra le 07:44:05 e le 07:44:48 e individua la coppia test_user / testpass .

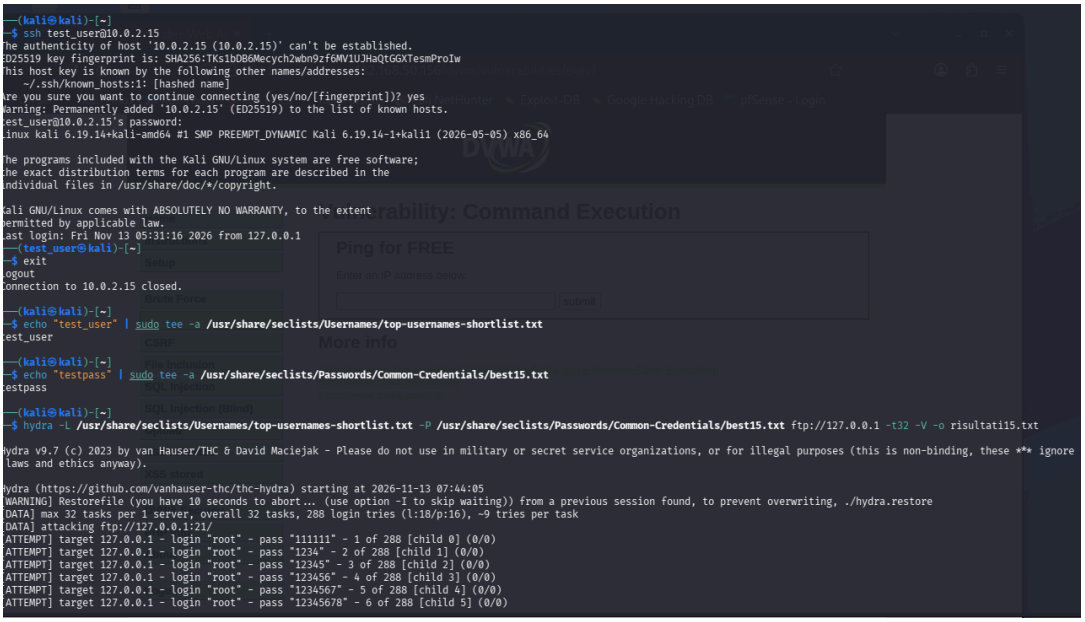


Figura 9 – Accesso SSH come test_user su 10.0.2.15; aggiunta delle righe alle liste SecLists; avvio dell'attacco FTP.

Limiti e note sul metodo

- Il test SSH verso 192.168.50.156 non è andato a buon fine. Il server ha offerto solo le chiavi host ssh-rsa e ssh-dss e il client non le ha negoziate: quell'host non è stato quindi valutato.
- Prima dell'attacco FTP le liste SecLists sono state integrate con le righe test_user (lista utenti) e testpass (lista password). Il successo dimostra quindi che il servizio accetta quella combinazione.

- Hydra ha segnalato un file di ripristino (hydra.restore) lasciato da una sessione precedente.
- La password impostata alla creazione di test_osg non è visibile nelle schermate: il valore riportato è quello confermato da Hydra.

3. Riepilogo dei rilievi

#	Rilievo	Gravità	Servizio
1	Password debole accettata sull'account SSH test_osg	Alta	SSH (22)
2	Password debole accettata sull'account FTP test_user, individuata con attacco a dizionario	Alta	FTP (21)
3	Nessun blocco osservato dopo 288 tentativi di login su FTP	Media	FTP (21)

Le osservazioni O1 e O2 non sono numerate come vulnerabilità e sono descritte nella sezione 5.

4. Dettaglio dei rilievi

4.1 Password debole sull'account SSH test_osg (Alta)

Descrizione

L'account test_osg, creatoper test, accetta la password testpass tramite SSH. La credenziale è stata confermata da Hydra con un singolo tentativo, senza liste.

Evidenze osservate

- Hydra con utente test_osg e password testpass verso 10.0.2.15 sulla porta 22, avviato alle 06:40:34: esito positivo.

Impatto

Chi conosce la password ottiene una shell remota con i privilegi dell'account test_osg. I privilegi effettivi dell'account non sono stati verificati in questo test.

Rimedi raccomandati

- Sostituire la password con una stringa lunga e casuale.
- Limitare gli accessi agli utenti necessari con la direttiva AllowUsers.

4.2 Password debole sull'account FTP test_user (Alta)

Descrizione

L'account test_user accetta la password testpass sul servizio vsftpd. La credenziale è stata individuata con un attacco a dizionario condotto con Hydra.

Evidenze osservate

- Attacco Hydra FTP con 18 utenti e 16 password, per un totale di 288 combinazioni, su 32 task paralleli. Avvio alle 07:44:05, conclusione alle 07:44:48 .
- Esito: login test_user con password testpass, «1 of 1 target successfully completed» .

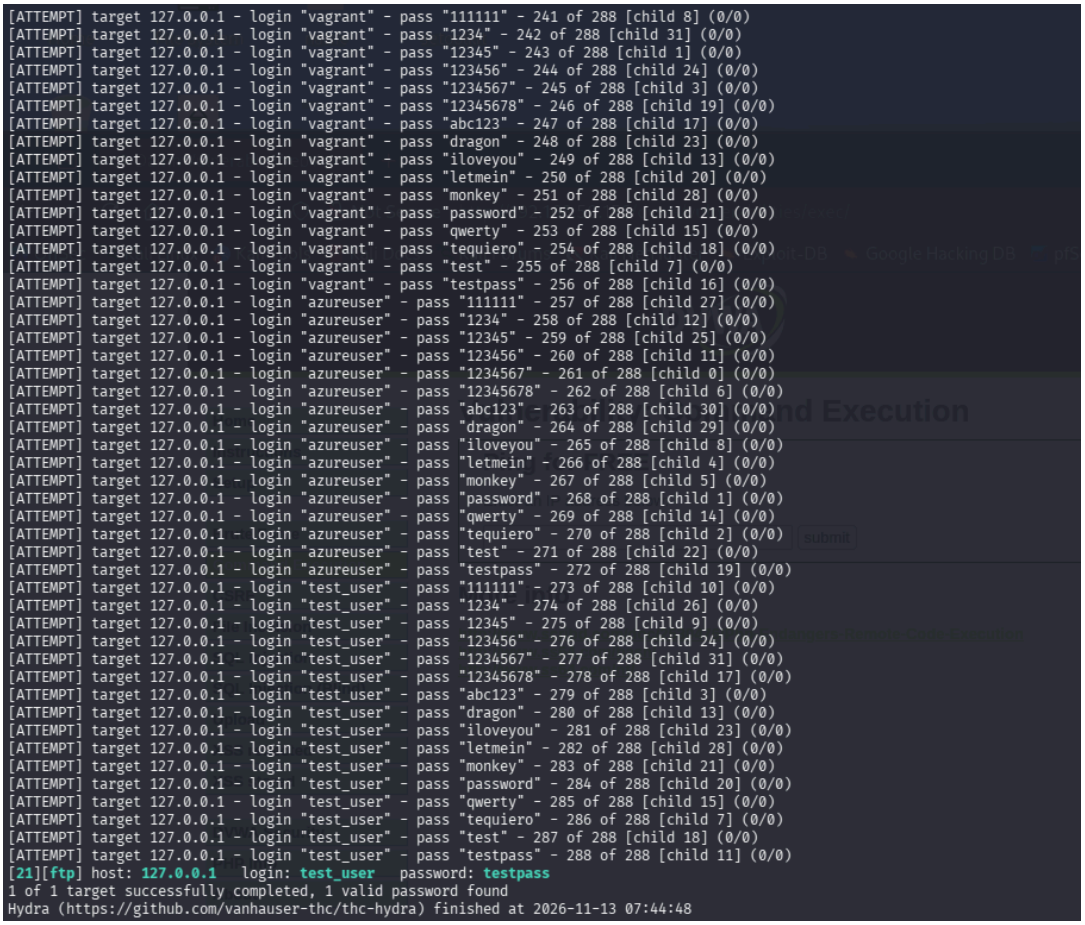


Figura 8 – Hydra su FTP: log dei 288 tentativi; la combinazione test_user / testpass viene accettata.

- Lo stesso account accede anche via SSH su 10.0.2.15 .

Impatto

Accesso ai file dell'utente sul server FTP, con lettura e scrittura secondo i permessi configurati.

Rimedi raccomandati

- Sostituire la password con una credenziale robusta.
- Sostituire FTP con SFTP (basato su SSH) oppure con FTPS, così le credenziali non viaggiano in chiaro.

4.3 Nessun blocco dopo ripetuti tentativi di login su FTP

Descrizione

Il servizio FTP non ha limitato il numero di tentativi di login. Nei log di Hydra visibili non compaiono blocchi o rifiuti di connessione durante i 288 tentativi, eseguiti in parallelo.

Evidenze osservate

- Log di Hydra con i tentativi numerati da 1 a 288, tutti eseguiti fino al completamento.

Impatto

Un attaccante può provare liste di credenziali senza essere fermato.

Rimedi raccomandati

- Bloccare temporaneamente gli indirizzi che superano una soglia di tentativi falliti, ad esempio con fail2ban sui log di vsftpd.
- Impostare un limite di tentativi per SSH con MaxAuthTries e limitare le connessioni simultanee per indirizzo.

5. Osservazioni

Le seguenti osservazioni non sono vulnerabilità confermate.

- O1 – Vsftpd è attivo ma non abilitato all'avvio. Il servizio non ripartirà dopo un riavvio.
- O2 – Il server su 192.168.50.156 offre solo ssh-rsa e ssh-dss come chiavi host.

6. Priorità di intervento

1. Sostituire subito le password degli account test_osg e test_user, oppure disattivarli.
2. Introdurre un limite ai tentativi di accesso su SSH e FTP.
3. Disabilitare l'autenticazione con password su SSH, passando alle chiavi pubbliche. Valutare la sostituzione di FTP con SFTP.

7. Riferimenti

- OWASP, Authentication Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- OWASP, Blocking Brute Force Attacks: https://owasp.org/www-community/controls/Blocking_Brute_Force_Attacks
- OpenBSD, sshd_config manual: https://man.openbsd.org/sshd_config

8. Conclusione

Le due credenziali deboli bastano a ottenere accesso remoto a due servizi della macchina. Le correzioni sono standard e a basso costo: cambiare le password, limitare i tentativi e passare alle chiavi su SSH.